



# Criptografía y Seguridad

Protección de datos

# El problema...

En una empresa se definen una política de protección de datos personales que dice:

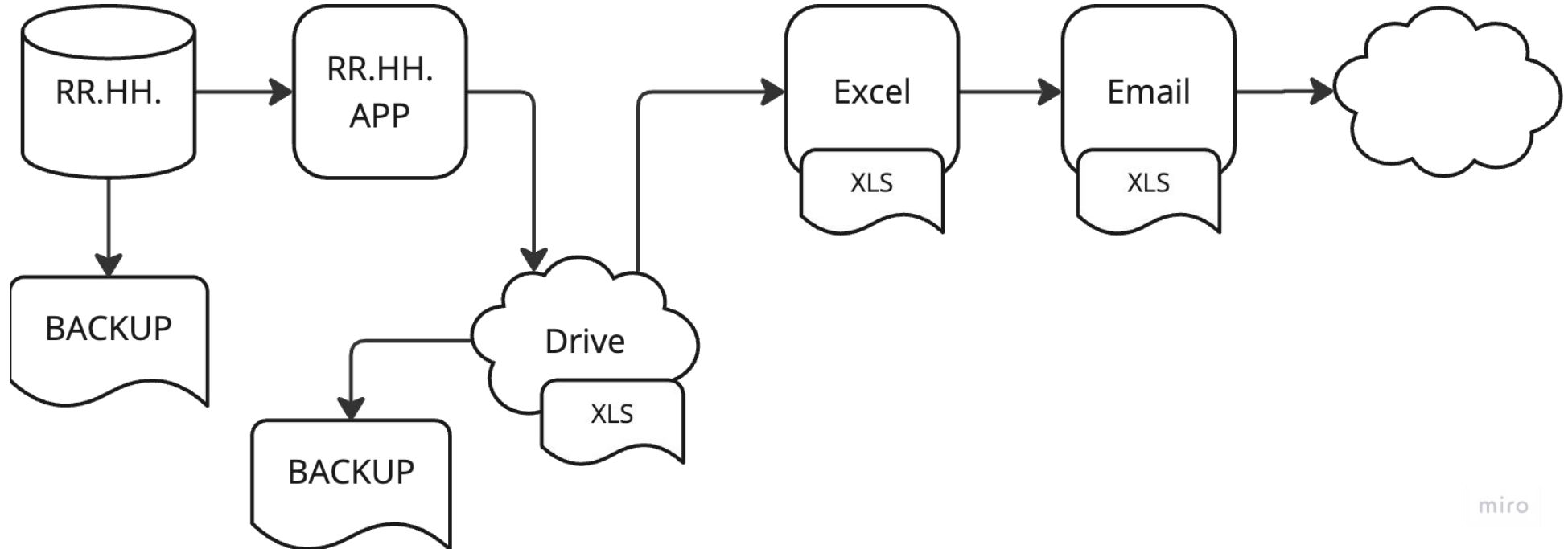
Un empleado no puede acceder a ver los sueldos de otros empleado.

Piensen un minuto en donde creen que habría que poner controles para proteger la información

# El problema...

En una empresa se definen una política de protección de datos personales que dice:

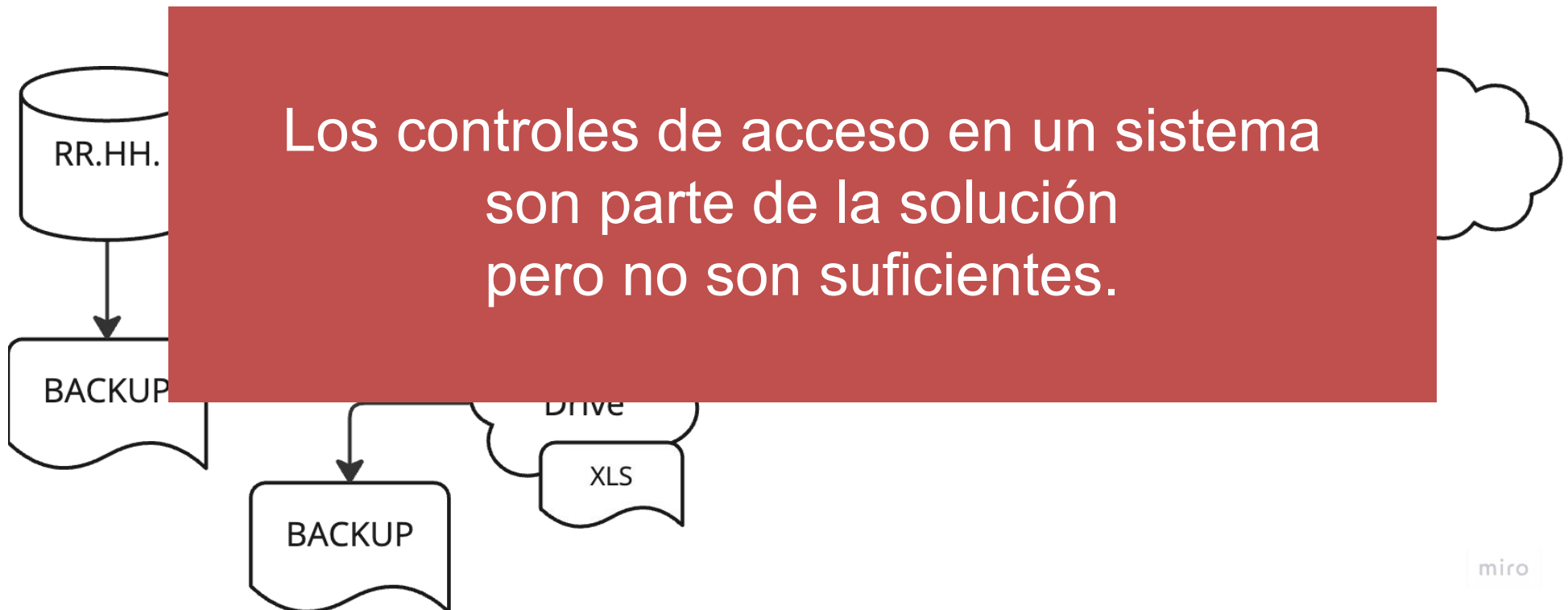
Un empleado no puede acceder a ver los sueldos de otros empleado.



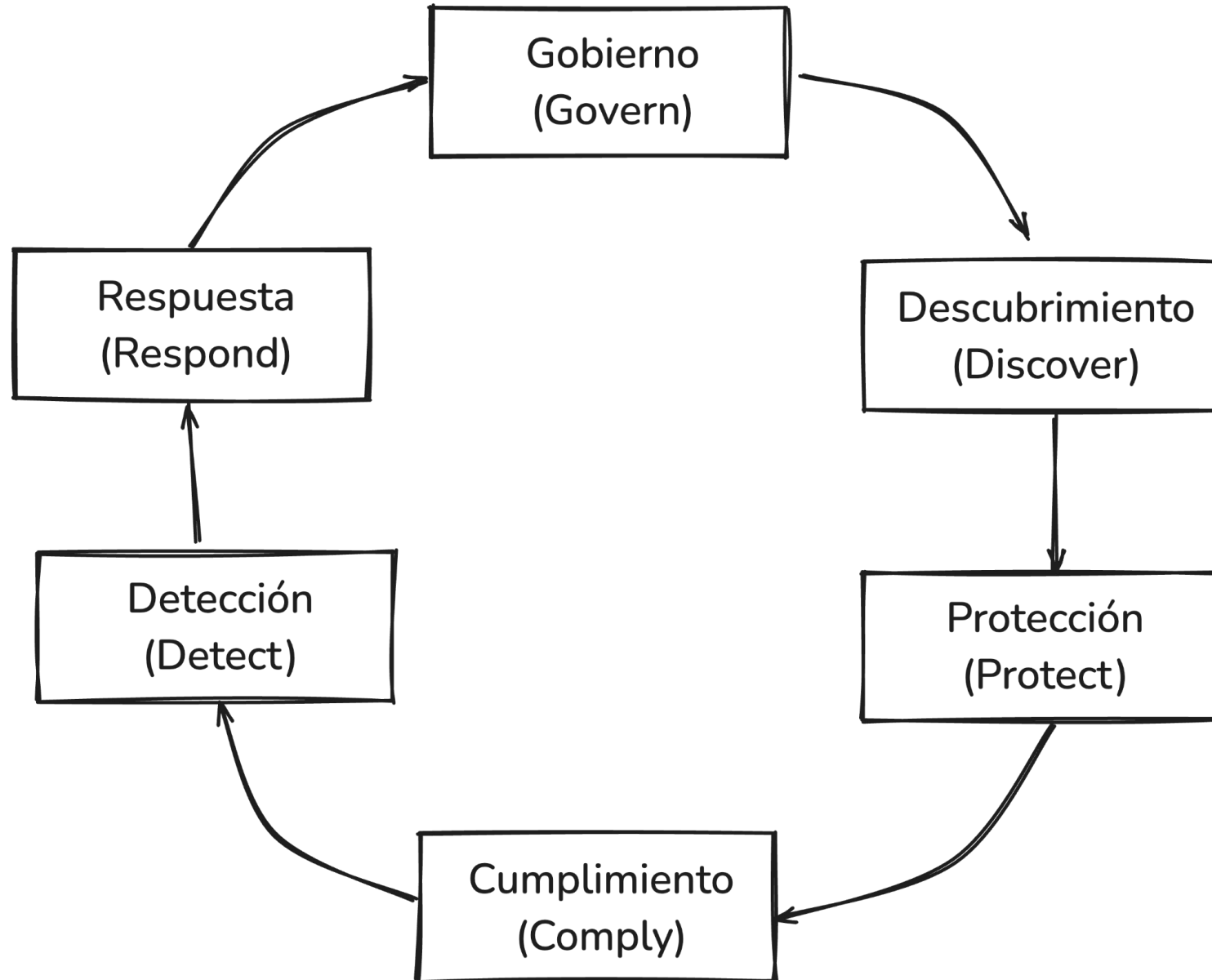
# El problema...

En una empresa se definen una política de protección de datos personales que dice:

Un empleado no puede acceder a ver los sueldos de otros empleado.



# Ciclo de la protección de la información





# Criptografía y Seguridad

Governance

# Data Governance

Son todas las tareas que se realizan para asegurar que los datos estén seguros, privados y integrales, y de que estén disponibles y se puedan usar.

Incluye las medidas que deben tomar las personas, los procesos que deben seguir y la tecnología que los respalda durante el **ciclo de vida de los datos**.

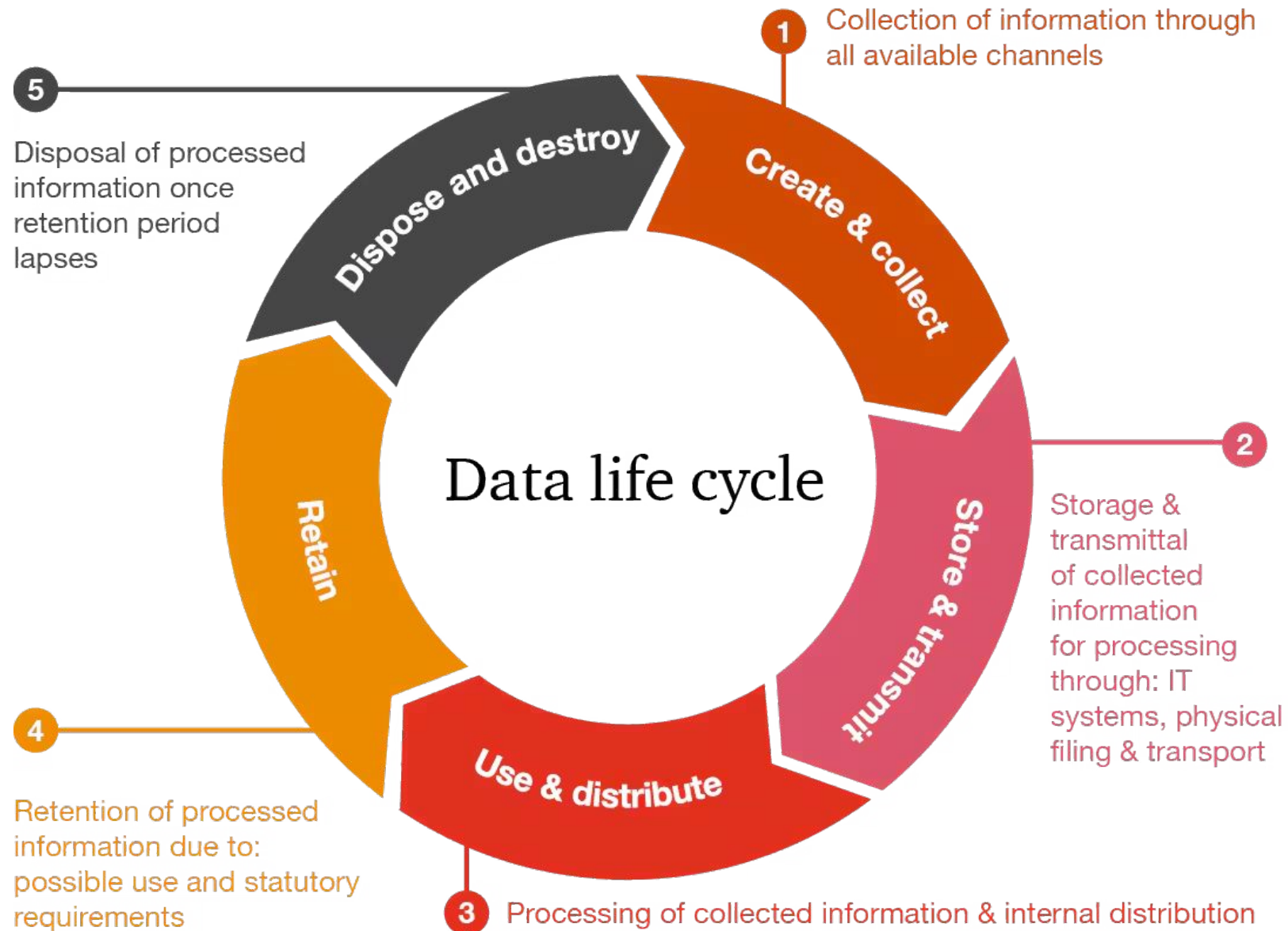
Define los roles dentro de la organización para el uso de la información.

# Data Governance

Establecen estándares internos (políticas de datos) que se aplican a la recopilación, almacenamiento, procesamiento, retención y eliminación de los datos.



# Data life cycle



# Regulaciones Externas

## Ley 25.326 Protección de datos personales

### **ARTICULO 1°** — (Objeto).

La presente ley tiene por objeto la protección integral de los datos personales asentados en archivos, registros, bancos de datos, u otros medios técnicos de tratamiento de datos, sean éstos públicos, o privados destinados a dar informes, para garantizar el derecho al honor y a la intimidad de las personas, así como también el acceso a la información que sobre las mismas se registre, de conformidad a lo establecido en el artículo 43, párrafo tercero de la Constitución Nacional.

### **ARTICULO 9°** — (Seguridad de los datos).

1. El responsable o usuario del archivo de datos debe adoptar las medidas técnicas y organizativas que resulten necesarias para garantizar la seguridad y confidencialidad de los datos personales, de modo de evitar su adulteración, pérdida, consulta o tratamiento no autorizado, y que permitan detectar desviaciones, intencionales o no, de información, ya sea que los riesgos provengan de la acción humana o del medio técnico utilizado.
2. Queda prohibido registrar datos personales en archivos, registros o bancos que no reúnan condiciones técnicas de integridad y seguridad.

# Regulaciones Internacionales

Health Insurance Portability and Accountability Act of 1996 (HIPAA)

Protección de datos relacionado con la salud de las personas (PHI-PPI)

General Data Protection Regulation (GDPR)

Protección de datos personales.

Aplicada en la Unión Europea en el 2018.

Payment Card Industry Data Security Standard (PCI-DSS)

Regulación del uso de información de tarjetas de crédito  
Obligatorio para cualquier empresa que desee realizar operaciones con tarjetas.

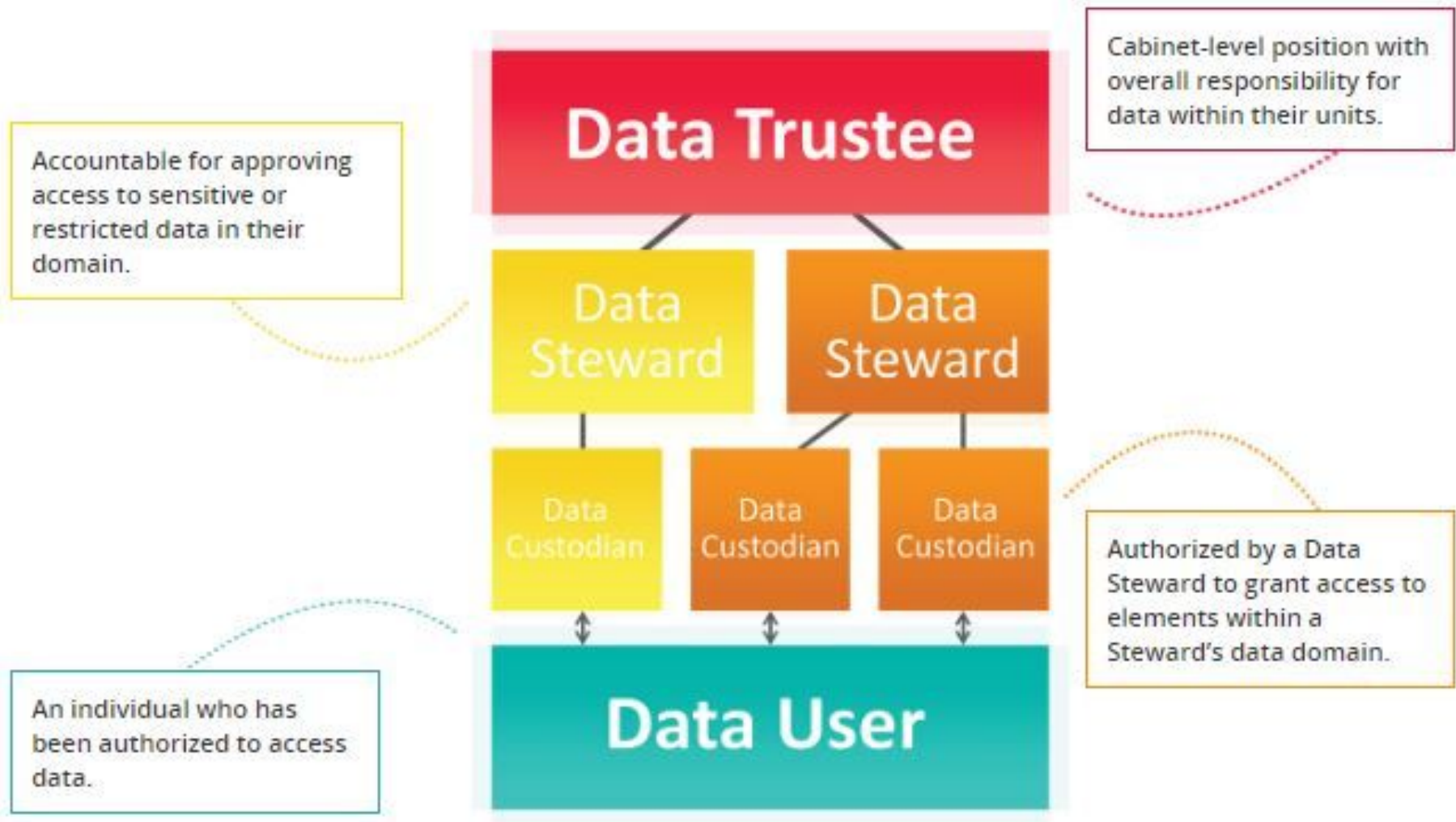
# Regulaciones Internacionales

SOX - Sarbanes-Oxley Act U.S. Fed law 2002

FFIEC - Assessment Tool

FDA Cybersecurity

# Data Roles







# Criptografía y Seguridad

Discovery

# Clasificación de los datos

## Planificar

- Identificar los activos
- Identificar los roles sobre esos datos
- Definir perfiles de acceso

## Ejecutar

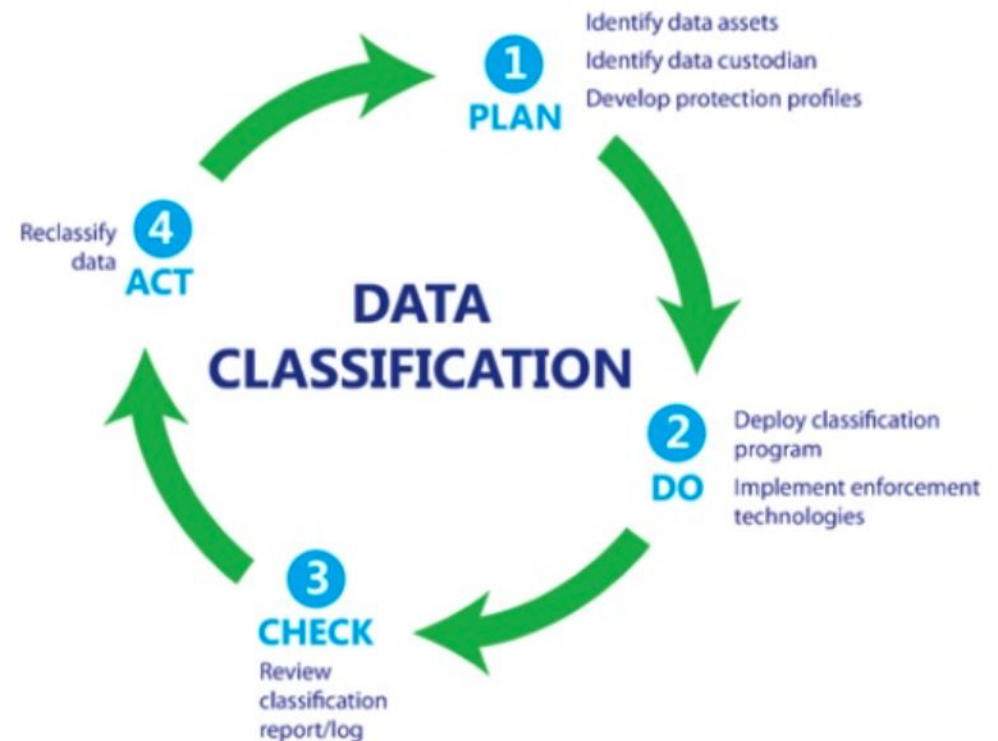
- Educar a los involucrados
- Desplegar la tecnología

## Monitorear

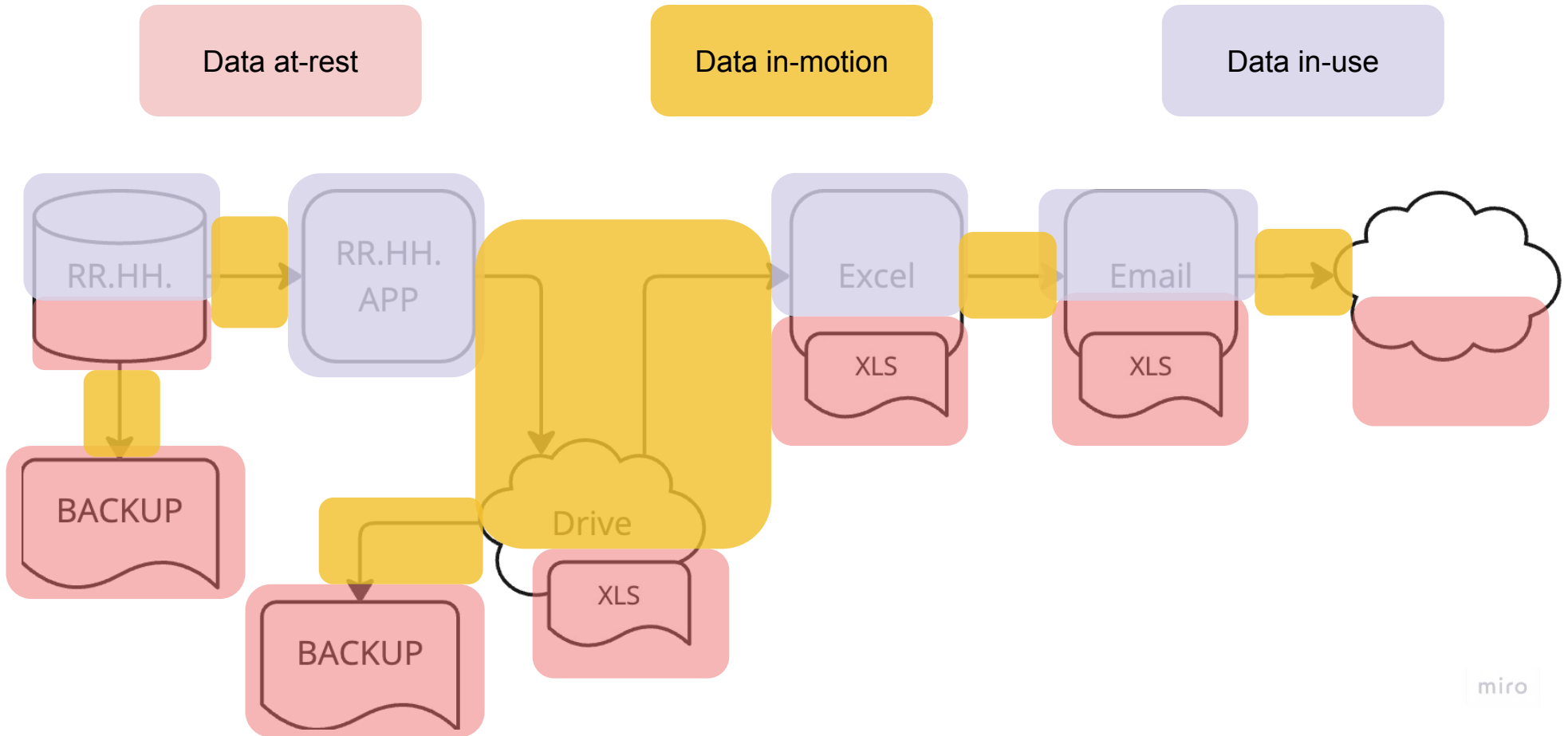
- Revisar log y alertas

## Reaccionar

- Reclasificar
- Bloquear/Permitir



# Mismo dato en distintos estados

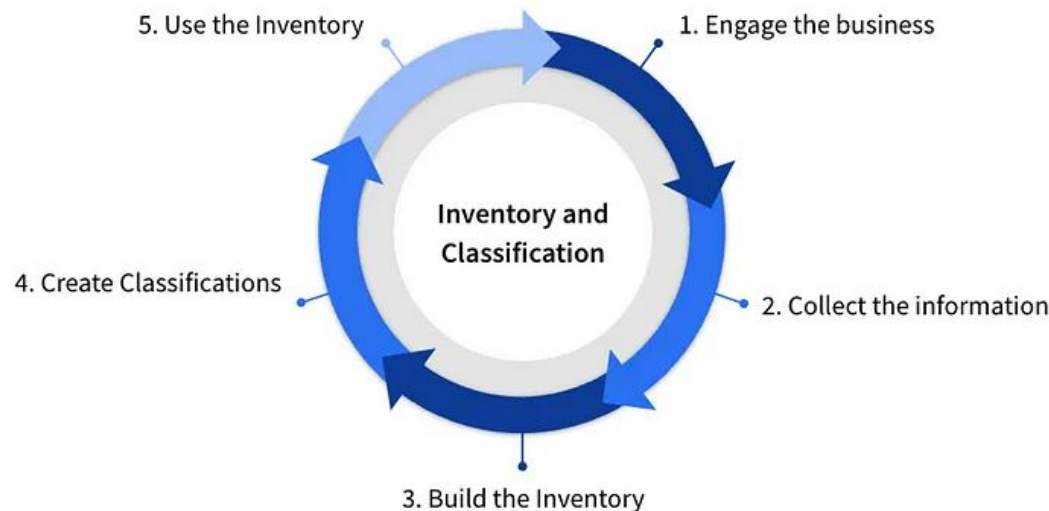




# Data Inventory

Identifica y registra todos los datos críticos, su ubicación, uso, clasificación y los responsables de los mismo.

Sirve de guía de referencia para la toma de decisiones, diseño de la seguridad y aplicación de políticas.



# Desafíos del Data Inventory

- Costo de mantenerlo actualizado

  - Tipos de datos

  - Flujos de los datos**

- Costo de inventariar

  - Descubrir nuevos tipos de datos

- Falta de educación en el uso del inventario

  - No se le saca provecho

- Son datos sensibles

  - Deben protegerse bajo las mismas reglas

- Complejo para la dinámica de las nuevas empresas, quedando rápidamente desactualizado.

# Data labeling

El modelo de data labeling busca inventariar los datos dentro los datos mismos (metadata)

Descentraliza el inventario pero permite que las etiquetas circulen con los datos.

Simplifica las reglas de protección y monitoreo.

No es un proceso estandarizado, por lo que los distintos sistemas deben traducir las etiquetas de un medio a otro.

La mayoría de los sistema modernos permiten la creación de etiquetas o metadata donde se puede guardar esta información.

# Ejemplo: AWS Tag Policy

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Principal": {
        "AWS": [
          "arn:aws:iam::111122223333:role/JohnDoe"
        ]
      },
      "Effect": "Allow",
      "Action": ["s3:GetObject", "s3:GetObjectVersion"],
      "Resource": "arn:aws:s3:::DOC-EXAMPLE-BUCKET/*",
      "Condition": {
        "StringEquals": {
          "s3:ExistingObjectTag/environment": "production"
        }
      }
    }
  ]
}
```

SUJETO

OBJETOS

ETIQUETA



# Criptografía y Seguridad

Protect

# Enforcement (Compiler-time)

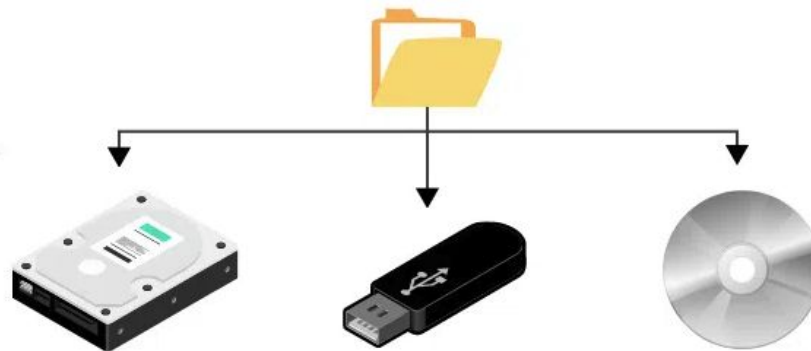
Asegura que el código cumple con ciertas políticas de seguridad antes de ser ejecutado.

Se realiza durante la fase de compilación del programa, donde el compilador analiza el código fuente para detectar posibles violaciones de las políticas de seguridad (análisis estático de código).

El compilador puede entonces asegurar que los datos clasificados como confidenciales no sean filtrados a variables o zonas de memoria de menor seguridad (ej. `SecureString` de Java)

# Encryption: En reposo (at-rest)

- Los datos en reposo son aquellos que no se mueven activamente de un dispositivo a otro ni de una red a otra, como los datos almacenados en un disco duro, un portátil, una unidad flash almacenados de alguna otra forma.
- La protección de datos en reposo tiene como objetivo proteger los datos inactivos.





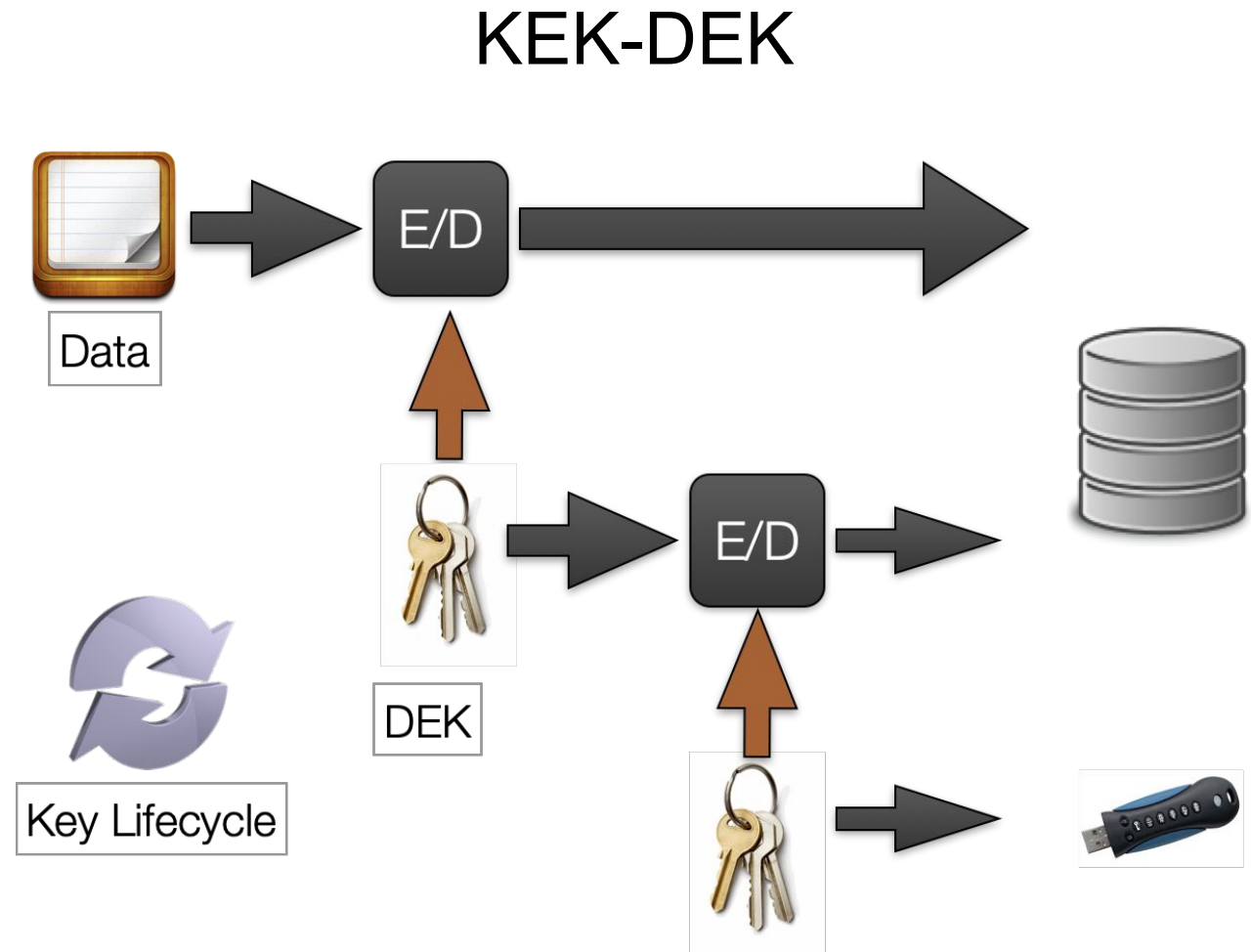
# Encryption: En reposo (at-rest)



Hardware Security Module (FIPS 1-4)

# Encryption: En reposo (at-rest) (Ejemplo)

- EncFS Loop-AES
- EFS Windows
- FileVault Mac OS X

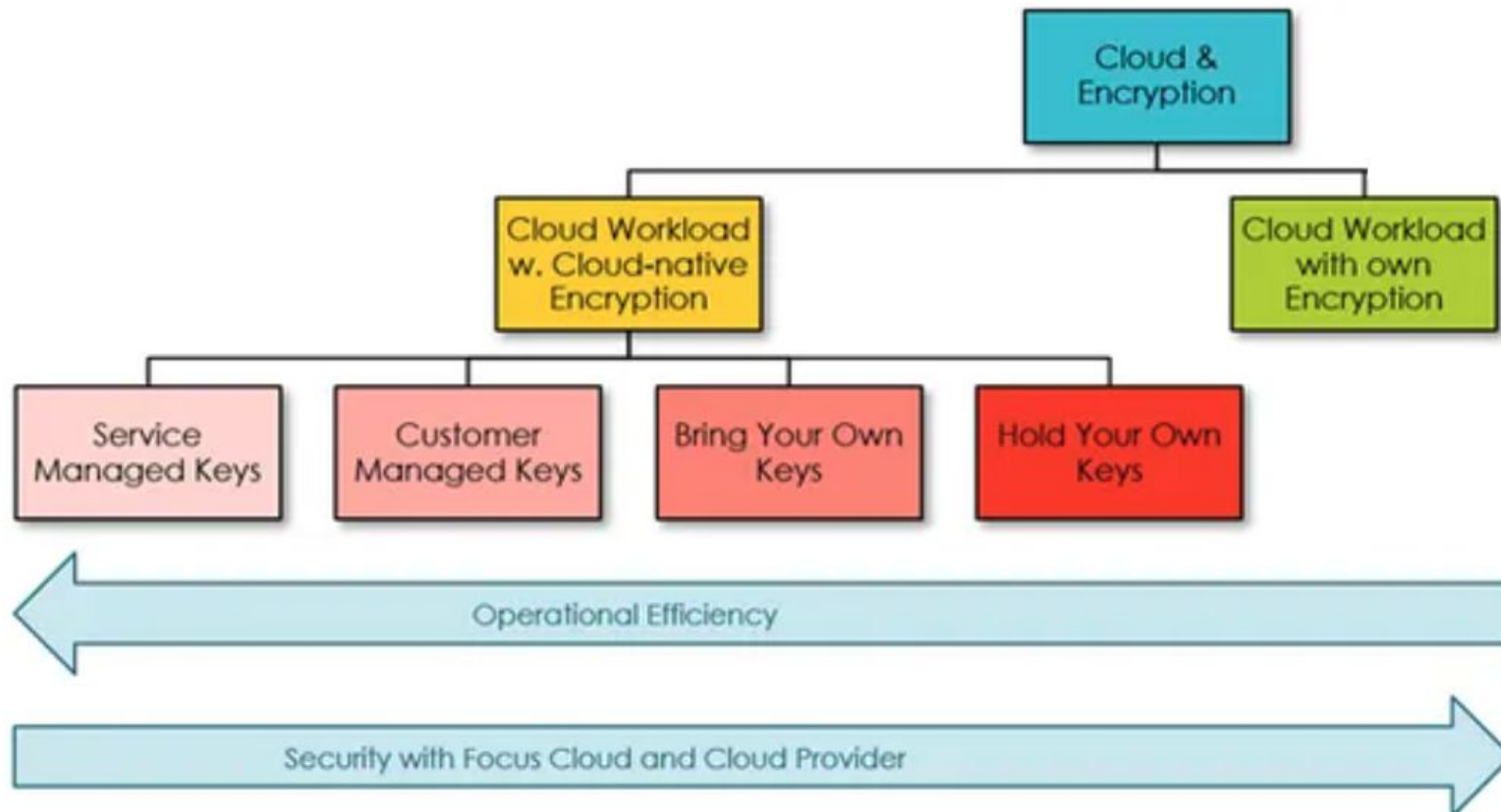


(X) Data Remanence  
(X) Secure Deletion

# Encryption: En reposo (at-rest) en la nube

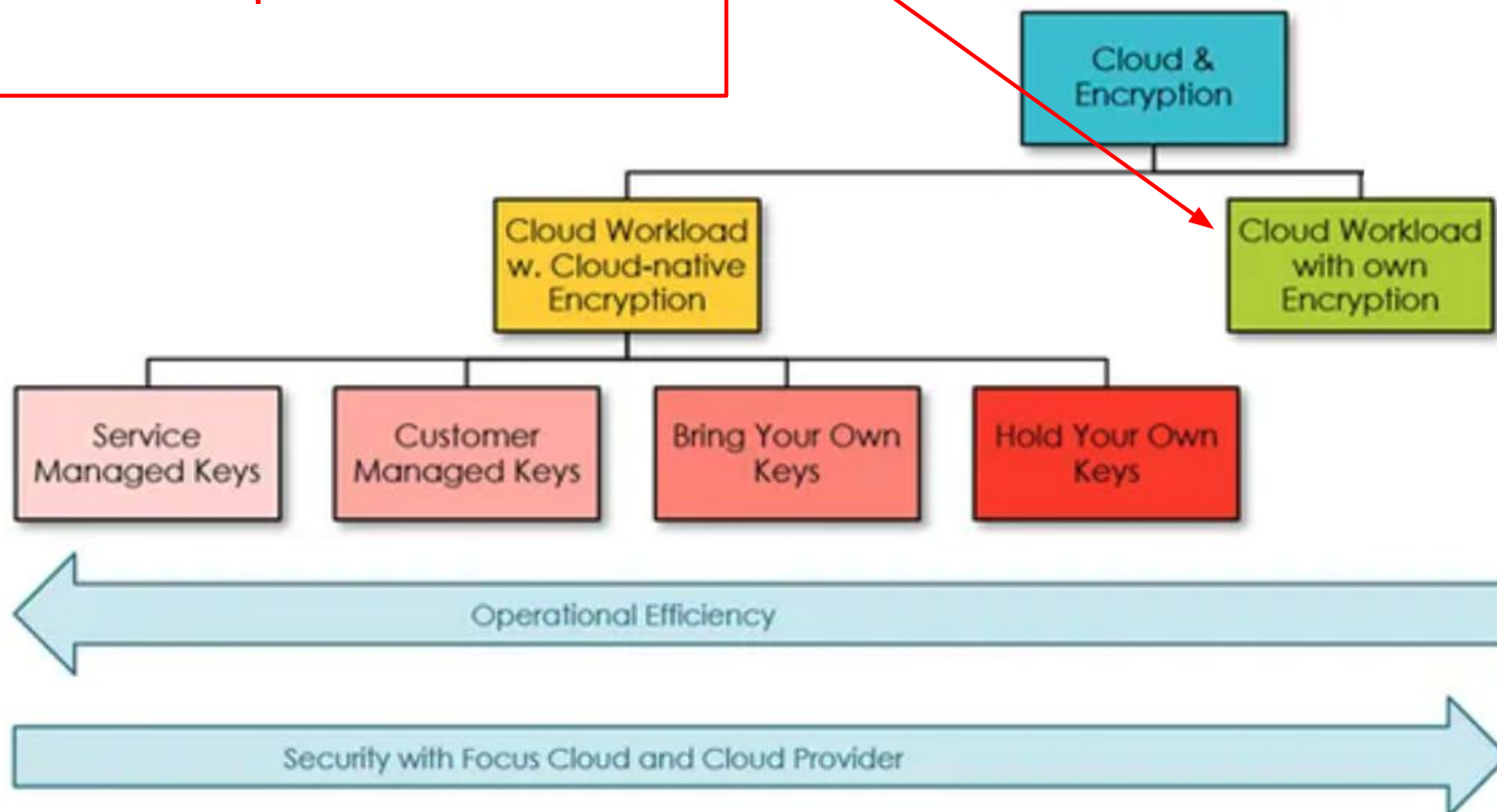
- La nube es infraestructura de terceros donde dejamos nuestros datos.
- La estrategia de encriptación que se elige requiere un esfuerzo del usuario de la nube.
- Mejor control de las claves de encriptación implica una lógica más compleja, y mayor costo operativo.
- Si el proveedor de nube se encarga de la encriptación, estamos delegando el control de las claves a un tercero, pero sin agregar costo operativo a mis procesos de negocio.

# Encryption: En reposo (at-rest) en la nube



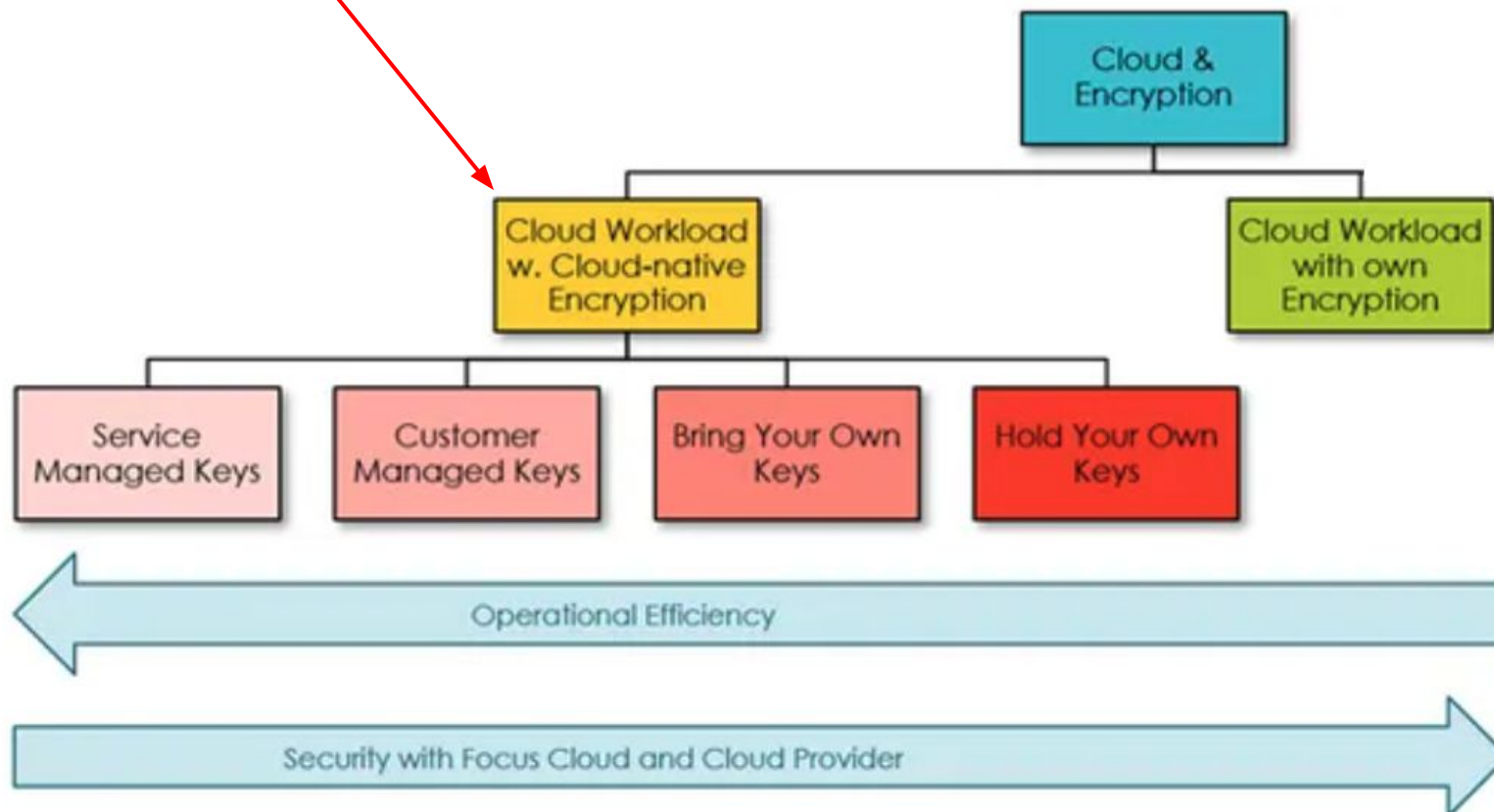
# Encryption: En reposo (at-rest) en la nube

Responsabilidad de encriptación del lado del proceso antes de almacenar la información en el disco.  
Independiente del proveedor de nube



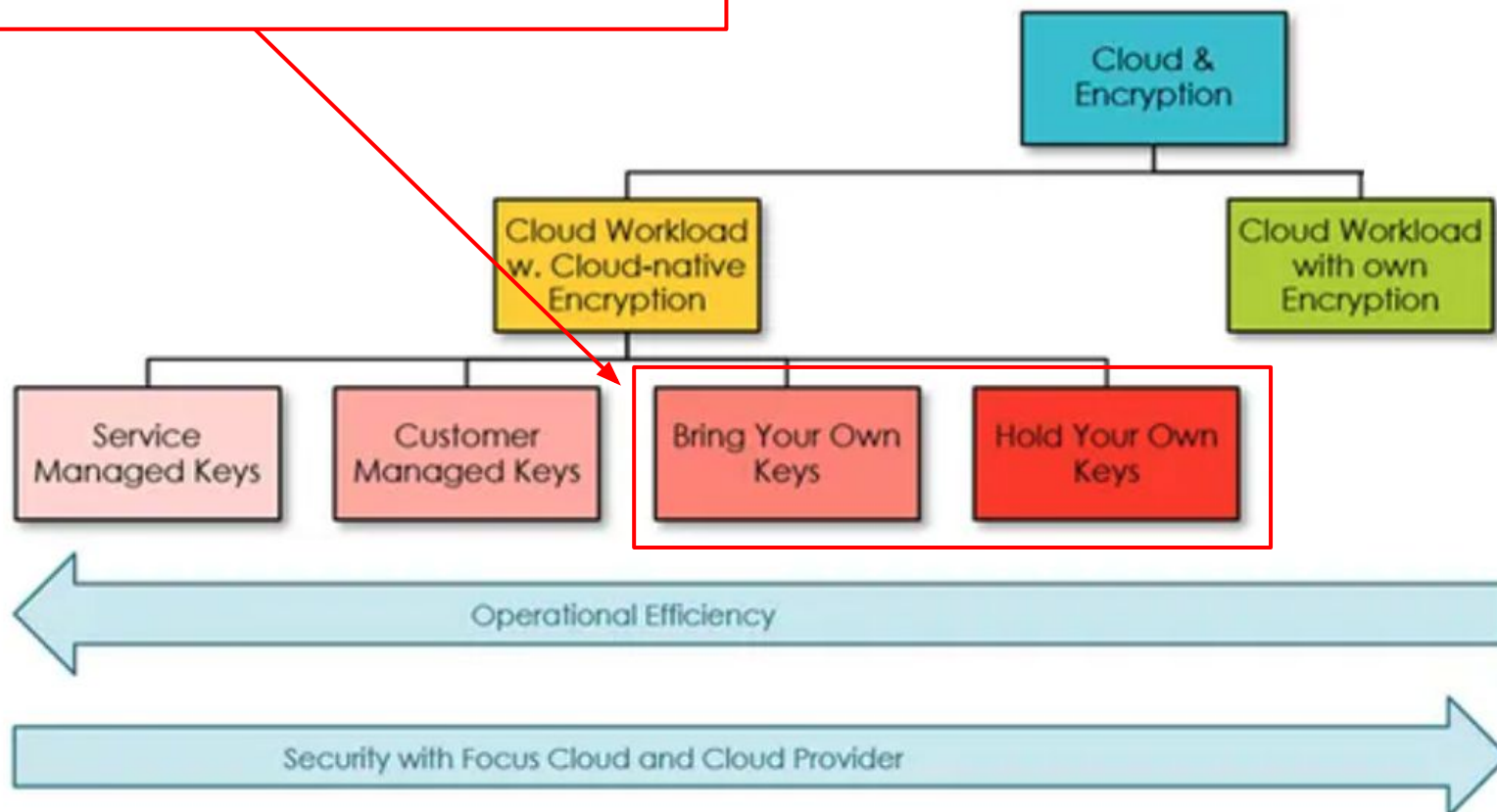
# Encryption: En reposo (at-rest) en la nube

Responsabilidad de encriptación del lado del proveedor de nube.



# Encryption: En reposo (at-rest) en la nube

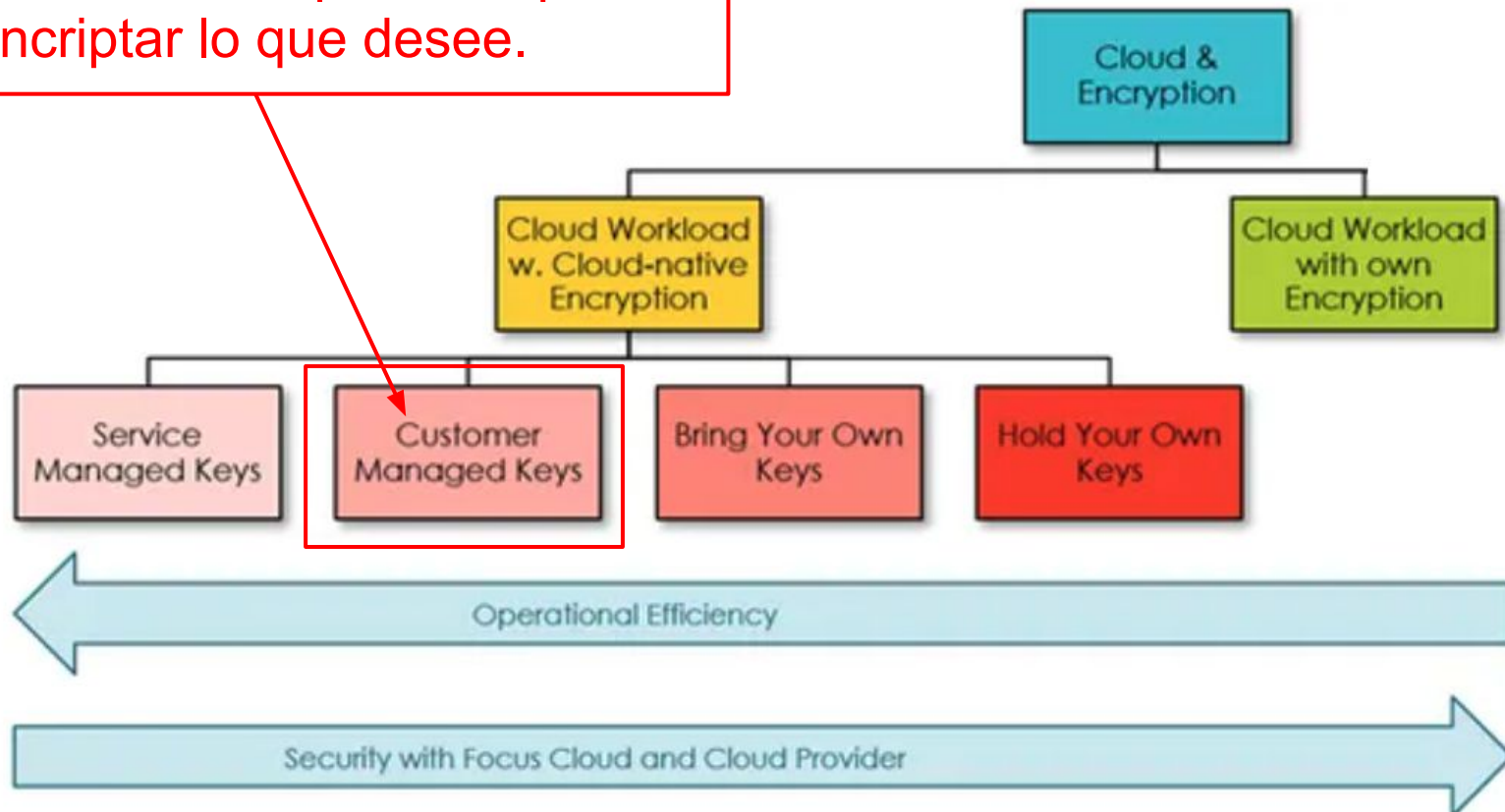
El cliente gestiona las claves de encriptación, posee las claves privadas y decide cuando realiza la rotación de las mismas





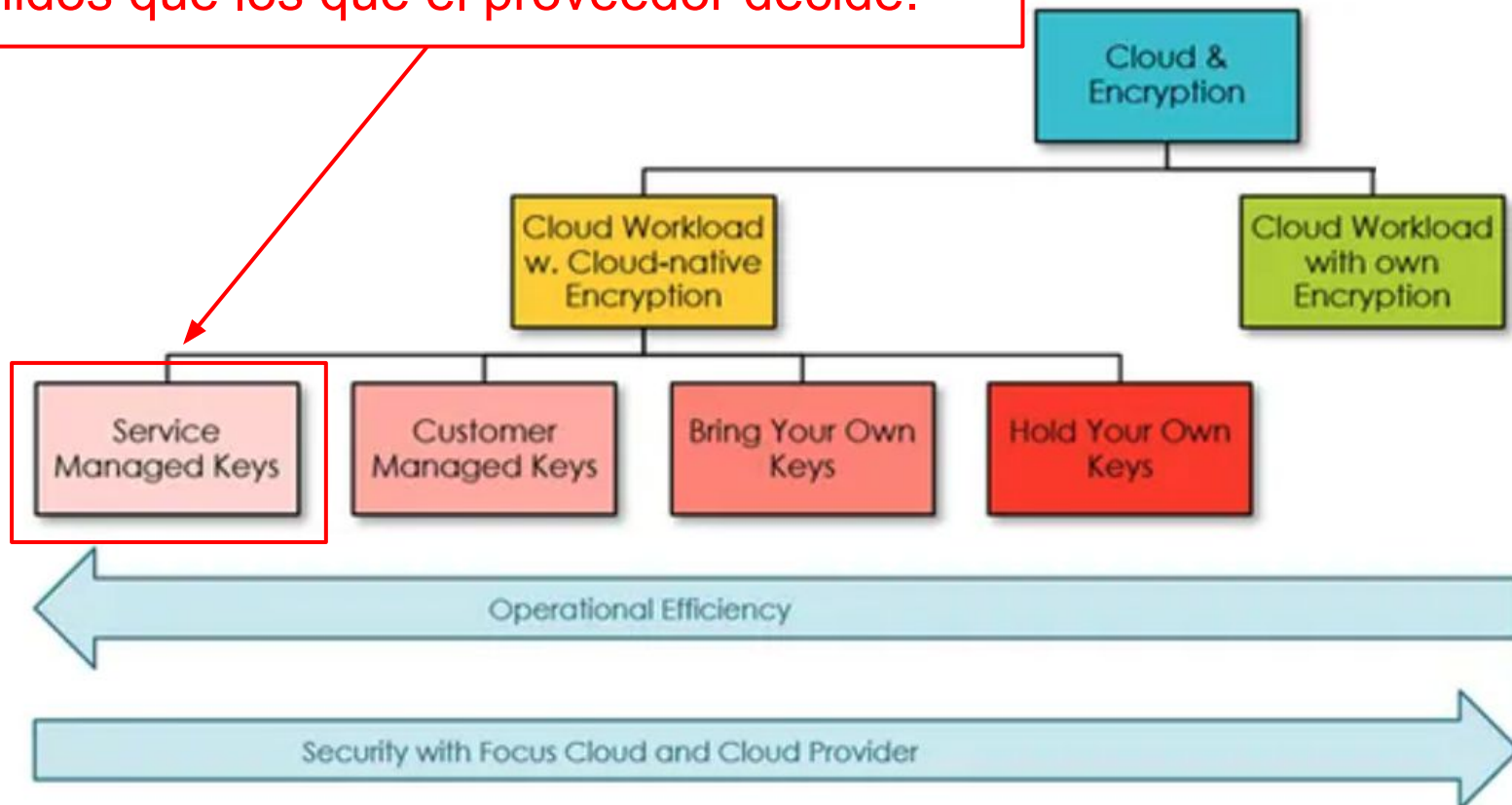
# Encryption: En reposo (at-rest) en la nube

El cliente gestiona las claves de encriptación y decide cuando realiza la rotación de las mismas. No puede acceder a las claves privadas pero puede encriptar lo que desee.



# Encryption: En reposo (at-rest) en la nube

El cliente no gestiona las claves de encriptación. El proveedor decide cuando realiza la rotación de las claves. No puede acceder a las claves privadas ni puede usarlas para encriptar otros contenidos que los que el proveedor decide.



# Encryption: En tránsito (in-transit)

- Los datos en tránsito, o datos en movimiento, son aquellos que se mueven activamente de una ubicación a otra, como a través de internet o de una red privada.
- Los datos pueden encriptarse antes de moverlos o usar protocolos de transporte que soporta encriptación.
  - Encriptación de un archivo con GPG antes de mandarlo por mail
  - Enviar el mail con el archivo usando SMTP sobre TLS.
- El uso de TLS, IPSEC, SSH son ejemplos de protocolos de encriptación in-transit.

# Enforcement (Execution-time)

Es la técnica de seguridad más utilizada para monitorear y controlar cómo se transmite la información entre distintos componentes de un sistema.

Se puede implementar a nivel aplicativo, o a nivel de infraestructura (Data loss Prevention DLP).

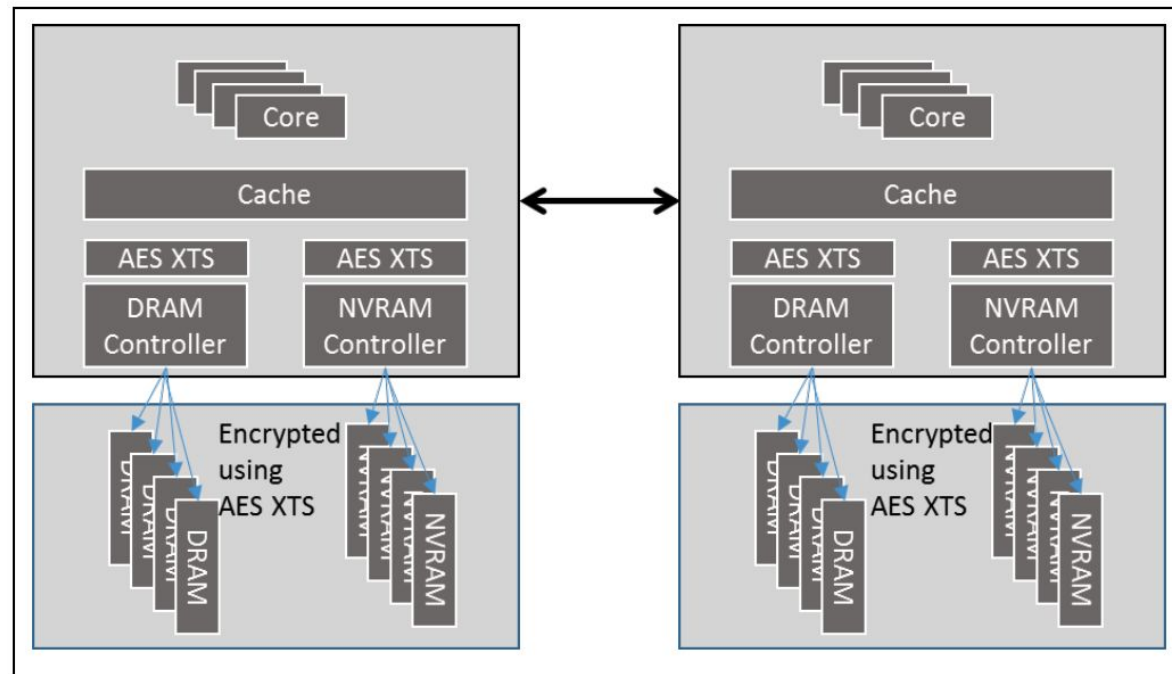
Requiere entender el movimiento de datos dentro de un sistema de información. Este movimiento puede ser entre procesos, entre diferentes niveles de seguridad o entre diferentes estados de un sistema.

# Encryption: en memoria

- Los datos en memoria podrían considerarse que están at-rest en memoria esperando que la CPU los use, o in-transit entre el bus IO y la CPU.
- Más allá de donde se los clasifique, en un ambiente de múltiples VMs accediendo a la misma memoria, existe el potencial riesgo de acceder información confidencial.
- Intel entre otros fabricantes implementó TME-MK, un mecanismo implementado en el hardware para gestionar encriptación de memoria basado en múltiples claves de encriptación.

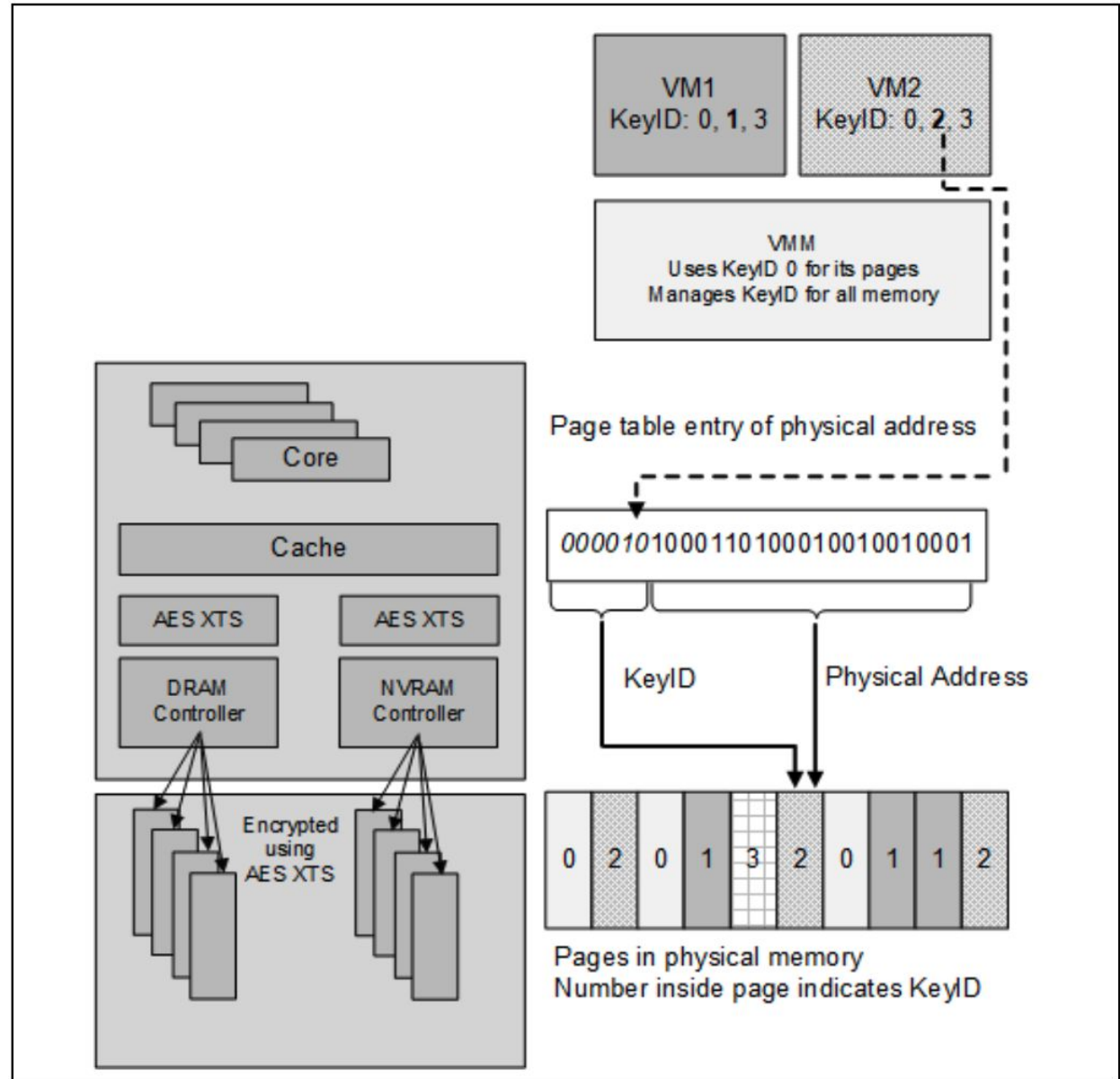
# Encryption: en memoria (TME)

- Total Memory Encryption (TME)
- Una sola clave de encriptación compartida por todos los procesos.
- La desenscriptación se realiza dentro de la CPU, antes del Cache



# Encryption: en memoria (TME-MK)

- Total Memory Encryption Multi-Key (TME-MK)
- Múltiples claves de encriptación, con un control de acceso soportado por los registros de VT-x





# Encryption: Homomorphic Encryption

- Implementar un esquema de encriptación que admita

$$f(x)=y \Rightarrow f(\text{Enc}(x)) = f(\text{Dec}(y))$$

# Encryption: SoC/IoT/Embedded Security

- Tampering-with
- Open Arch
- Debug complejo debug/seguridad
- Wireless
- Diversidad / Escala
- Riesgo Físico

Perception Layer  
Application Layer  
Network Layer





# Criptografía y Seguridad

Comply

# Cumplimiento



# Cumplimiento

Todas las regulaciones internacionales y comerciales que vimos al principio define una serie de reglas e imponen un proceso de auditoría y certificación que las empresas deben cumplir.

Todos los procesos, tecnología y personas dedicadas a la protección de los datos deben dejar registro de sus acciones y la evidencia de que están funcionando correctamente

# Cumplimiento (Retención)

Se denomina retención de la información el guardado de la información que ya no es necesaria, usualmente por temas regulatorios.

La retención tiene fines legales, o de análisis forense.

The HIPAA log retention requirements are that if a log, note, or record relates to a HIPAA policy or procedure, the log, note, or record must be retained for **six years from the date the content was last used or was last effective.** Mar 6, 2024

Requirement 3.1 of the Payment Card Industry Data Security Standard (DSS) requires organizations to retain and follow data retention and disposal procedures. The purpose of the [data storage and destruction procedure](#) is to ensure that records no longer needed are deleted promptly and adequately.

## SOX Retention Requirements – 7 Years

Sarbanes-Oxley Act of 2002 (SOX) was modified in 2003 to require relevant auditing and review documents to be retained for seven years after the audit or review of the financial statements is concluded.





# Criptografía y Seguridad

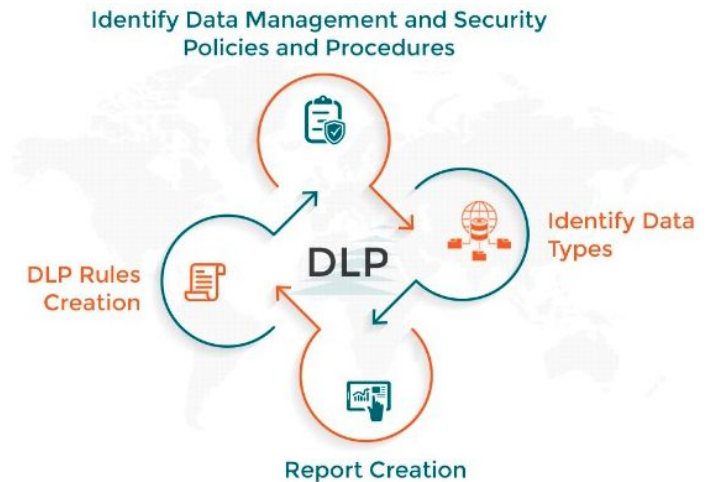
Detect

# Data Loss Prevention (DLP)

Los DLP son herramientas que ayudan en el proceso de clasificación, inventariados y detección de información, en todos sus estados.

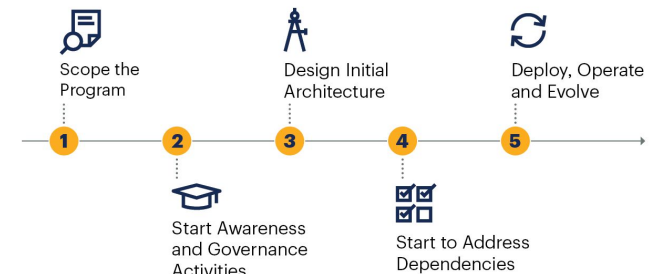
No están orientados se un control preventivo o correctivo, sino detectivo. Se activa cuando se produce una falla en la aplicación de una política.

Son complejos de implementar.



## Five Steps to a Successful DLP Implementation Framework

DLP Implementation Framework



gartner.com

Source: Gartner  
© 2022 Gartner, Inc. All rights reserved. PR\_1639927

Gartner



# DLP hoy en día

Las herramientas de DLP fueron muy difíciles de implementar por que a

dife

de s

esfu

Tod

nacieron haciendo DLP fueron

compradas e incorporadas a

otras soluciones.

Hoy en día las funcionalidades de DLP están incorporadas en productos que usan a diario.





# Criptografía y Seguridad

Response

# Respuesta ante un incidente



**Record the  
date and time**



**Alert  
everyone**



**Secure the  
premises**



**Stop  
exfiltration of data**



**Document  
everything**

## WHAT TO DO IN THE FIRST 24 HOURS



**Interview  
anyone involved**



**Review  
communications  
protocols**



**Assess  
priorities and risks**



**Bring in a  
forensic team**



**Notify law  
enforcement**

# Respuesta ante un incidente







Fin!!